

Requirements Engineering Specification

Enterprise-Grade Online Banking System (OBS)

Systems Analysis and Design (SAD) Course Project

Phase 1: Requirements Extraction, Analysis, and Specifications

Student Name: Ahmad Ghanavati

Student ID: 40273116

Instructor: _____

Academic Term: Spring Semester, Khordad 1405 (June 2026)

Contents

1	Introduction	2
1.1	System Overview	2
1.2	System Scope & Core Operational Boundaries	2
1.3	Target User Base & System Actors	2
2	Functional Requirements	4
3	Non-Functional Requirements	8
4	Form-Based Specifications for Core Transactions	10
4.1	Core Transaction 1: User Registration & MFA Setup	11
4.2	Core Transaction 2: Secure Login & Session Initialization	12
4.3	Core Transaction 3: Domestic Fund Transfer (Intra-Bank & ACH/Wire)	13
4.4	Core Transaction 4: Automatic Bill Payment & Utility Registration	14
4.5	Core Transaction 5: Statement Generation & PDF Export	15
5	Graphical UML Notations	16
5.1	UML Use Case Diagram	16
5.2	UML Sequence Diagram (Domestic Fund Transfer Workflow)	17
6	Requirements Traceability & Verification Matrix	18
6.1	Functional Requirements Traceability Matrix	18
6.2	Non-Functional Requirements Traceability Matrix	20

1. Introduction

1.1. System Overview

The Online Banking System (OBS) is a central web application designed to handle day-to-day financial operations for retail and corporate bank customers. The system serves as the primary digital interface, connecting the bank's core banking database infrastructure with user-facing devices. It provides integrated interfaces for account monitoring, domestic funds transfer, utility bill payments, real-time alerts, and self-service account management.

1.2. System Scope & Core Operational Boundaries

The scope of the OBS covers the development of five core application modules:

- **Secure Authentication:** Customer signup, secure login, multi-factor authentication (MFA) via SMS or authenticator apps, and security log recording.
- **Account Management:** Real-time balance checks, interest tracking, profile management, and account ledger updates.
- **Funds Transfer System:** Instant and scheduled transfers, supporting intra-bank transactions, ACH transfers, and high-value wire transfers (RTGS).
- **Utility Billing & Automated Payments:** Direct integration with external billing services (such as electricity, water, and telecom providers) and automatic recurring payment configurations.
- **Reporting & PDF Statements:** On-demand generation and downloading of transaction histories in a structured, standard PDF format.

1.3. Target User Base & System Actors

The OBS coordinates operations among five distinct user roles and external systems:

1. **Individual Customer (Primary Actor):** A retail customer who uses the application for personal accounts management, transfers, bill payments, and statement retrieval.
2. **Corporate Customer (Primary Actor):** A business user executing larger, bulk transfers (ACH/RTGS) that require multi-step authorization workflows and corporate reporting.
3. **System Administrator (Secondary Actor):** An IT administrator responsible for platform configuration, managing user roles, checking backups, and reviewing audit logs.

4. **Bank Teller (Secondary Actor):** A bank employee who handles customer disputes, verifies manual transfer overrides, and reviews transaction logs.
5. **Third-Party APIs (External Actors):** Clearing networks (Shetab, RTGS, ACH), external SMS gateway services, and government identity verification databases.

2. Functional Requirements

Functional requirements define the core operations, transactions, and services that the Online Banking System must perform. To ensure the specifications are accessible to business stakeholders while remaining technically rigorous for developers and testers, each requirement is presented in a dual format:

- **User Requirements:** Written in non-technical natural language to describe the features from a customer's perspective.
- **System Requirements:** Detailed engineering specifications that use strict "***shall**" terminology to define absolute system obligations, protocols, and technical constraints.

The requirements are organized into eight operational categories and mapped in the matrices below.

Table 1: Online Banking System - Functional Requirements Specification (Part 1)

Req. ID	Category	User Requirement	System Requirement ("Shall" wording)
OBS-FR-01 <i>[Must]</i>	Authentication	Users must be able to register secure accounts online.	The system shall provide a customer registration interface that validates the email, phone number, and national ID, and cryptographically hashes the password prior to database persistence.
OBS-FR-02 <i>[Must]</i>	Authentication	Users must log in securely with two-factor validation.	The system shall enforce secure multi-factor authentication (MFA) by requiring a 6-digit Time-Based One-Time Password (TOTP) or SMS token after primary credential validation.
OBS-FR-03 <i>[Must]</i>	Authorization & Access Control	Different user roles must have distinct and restricted platform privileges.	The system shall enforce Role-Based Access Control (RBAC) schemas, dynamically rendering the dashboard and features according to the authenticated user's role (Customer, Teller, or Administrator).
OBS-FR-04 <i>[Should]</i>	Authorization & Access Control	Administrative logins must be audited, and idle sessions terminated.	The system shall automatically invalidate and terminate any administrative user session that remains inactive for more than 10 consecutive minutes.
OBS-FR-05 <i>[Must]</i>	Data Processing	Customers should see updated account ledger data immediately.	The system shall execute ACID-compliant database transaction queries, instantly updating checking and savings ledgers upon completion of a debit/credit operation.
OBS-FR-06 <i>[Must]</i>	Data Processing	User input must be checked for safety before processing.	The system shall sanitize and validate all client-side form fields and query strings on the server side to protect against SQL Injection, XSS, and buffer overflow attempts.
OBS-FR-07 <i>[Should]</i>	UI/UX	The application must work on mobile, tablet, and desktop screens.	The system shall utilize fluid grid layouts and responsive CSS media queries, rendering dashboards consistently across viewport resolutions from 320px to 2560px.
OBS-FR-08 <i>[Should]</i>	UI/UX	Visually impaired users must be able to read screens easily.	The system shall conform to the W3C Web Content Accessibility Guidelines (WCAG) 2.1 AA standards, supporting high-contrast styling and screen readers.

Table 2: Online Banking System - Functional Requirements Specification (Part 2)

Req. ID	Category	User Requirement	System Requirement ("Shall" wording)
OBS-FR-09 <i>[Must]</i>	Reporting	Customers should be able to download their statement documents.	The system shall compile checking and savings transaction history into a secure PDF format on demand, initiating the browser download immediately.
OBS-FR-10 <i>[Could]</i>	Reporting	Managers must get automated summaries at month-end.	The system shall compile a consolidated bank-wide monthly financial ledger report at 23:59:59 on the last day of each month and dispatch it to the management team.
OBS-FR-11 <i>[Must]</i>	Third-Party Integrations	Customers must be able to transfer money to external bank accounts.	The system shall securely transmit transaction data to the national Shetab and RTGS clearing house API endpoints using authenticated secure connection protocols.
OBS-FR-12 <i>[Must]</i>	Third-Party Integrations	Users must receive transaction confirmation messages immediately.	The system shall trigger a notification request to the external SMS Gateway API within 2 seconds of any successful transaction exceeding \$10.00.
OBS-FR-13 <i>[Should]</i>	Error Handling & Logging	Users must be clearly informed when operations fail.	The system shall display a modal window with a non-technical error description and actionable resolution steps when a network timeout or data validation exception occurs.
OBS-FR-14 <i>[Must]</i>	Error Handling & Logging	Tech teams must have detailed security logs for errors.	The system shall write all security-sensitive events, database transaction failures, and validation errors into a centralized log management server for review and security auditing.
OBS-FR-15 <i>[Must]</i>	Backup & Restore	Financial ledgers must be backed up daily to prevent data loss.	The system shall run an automated daily snapshot backup of the relational database at 02:00:00 local time, writing encrypted backups to secure offsite cloud storage.
OBS-FR-16 <i>[Must]</i>	Backup & Restore	A recovery site must be maintained for rapid restoration.	The system shall support warmstandby database replication to a geographically separate data center, allowing recovery within 30 minutes in case of disaster.

Table 3: Online Banking System - Functional Requirements Specification (Part 3)

Req. ID	Category	User Requirement	System Requirement ("Shall" wording)
OBS-FR-17 <i>[Could]</i>	Authentication	Enterprise clients and internal bank operators should be able to log in using standard company identity providers.	The system shall integrate with enterprise Single Sign-On (SSO) identity providers via OAuth 2.0 / SAML 2.0 protocols to authenticate corporate users and bank staff securely.
OBS-FR-18 <i>[Could]</i>	Data Processing	Customers should be able to search and filter their transaction history and payees.	The system shall provide multi-criteria database query filters allowing users to search transactions by date range, transaction type, amount range, and counterparty payee name within 1.5 seconds.
OBS-FR-19 <i>[Should]</i>	Third-Party Integrations	Customers must receive alerts for high-risk actions, scheduled transfers, and low balances via multiple channels.	The system shall dispatch automated alerts via push notifications, email, and SMS microservices for any balance drops below customer-set thresholds, suspicious login attempts, or scheduled transfer executions.
OBS-FR-20 <i>[Should]</i>	Error Handling & Logging	Users must be able to submit support tickets or system feedback directly in the app.	The system shall provide an in-app helpdesk ticketing dashboard that allows users to submit, view, and rate support requests, automatically capturing client device logs and routing the tickets to the Bank Operator console.

3. Non-Functional Requirements

Non-functional requirements (NFRs) define the system's operational constraints, quality attributes, and performance benchmarks. To allow objective evaluation, these requirements are specified using quantitative and testable criteria organized across seven core categories.

Table 4: Online Banking System - Non-Functional Requirements Matrix

Req. ID	Category	User Requirement	System Requirement (Quantitative & Testable)
OBS-NFR-01 <i>[Should]</i>	Usability	The user dashboard must be highly intuitive.	The application dashboard shall be designed such that first-time users can complete their initial transfer setup in less than 3 minutes, with a task success rate greater than 95%.
OBS-NFR-02 <i>[Must]</i>	Security	Sensitive customer and bank database files must be encrypted.	The system shall encrypt all persistent database storage volumes at rest using the AES-256 standard and secure all APIs and communication channels in transit using TLS 1.3.
OBS-NFR-03 <i>[Must]</i>	Security	Passwords must be protected using modern hashing.	The system shall hash all user-entered passwords prior to database storage using the Argon2id cryptographic hashing algorithm with a minimum memory cost of 64MB.
OBS-NFR-04 <i>[Must]</i>	Reliability	Transactions should never result in partial states or lost data.	The system database engines shall guarantee full transactional integrity, enforcing ACID principles to automatically roll back any transaction that fails mid-execution.
OBS-NFR-05 <i>[Must]</i>	Performance	Page loads must be fast even under heavy usage.	The system shall load and display individual user dashboard pages in less than 2.0 seconds under normal conditions and less than 3.0 seconds under peak load.
OBS-NFR-06 <i>[Should]</i>	Scalability	The system should support many users concurrently.	The platform application architecture shall maintain standard operation at up to 100,000 concurrent active user sessions without showing throughput degradation.
OBS-NFR-07 <i>[Must]</i>	Availability	The online banking portal must stay online constantly.	The system shall maintain an overall service availability uptime of 99.99% over any given calendar month, restricting planned downtime to pre-announced hours.
OBS-NFR-08 <i>[Should]</i>	Compatibility	The portal must work identically on all devices.	The application shall render and perform identically on Google Chrome, Mozilla Firefox, Apple Safari, Microsoft Edge, Android (v9.0+), and iOS (v14+).
OBS-NFR-09 <i>[Must]</i>	Reliability	If the primary site fails, the system must recover with minimal data loss and quick restoration.	The database restoration workflows shall achieve a Recovery Point Objective (RPO) of ≤ 1 hour and a Recovery Time Objective (RTO) of ≤ 2 hours, validated by bi-weekly database restoration tests.

4. Form-Based Specifications for Core Transactions

To provide greater detail for the key functional areas of the system, this section presents structured natural language specifications for the five core banking transactions. Each transaction is detailed using a standard specification template that maps out inputs, outputs, preconditions, postconditions, and the specific sequential logic required for implementation.

4.1. Core Transaction 1: User Registration & MFA Setup

Structured Form-Based Specification: OBS-SRS-FR-01.00	
Requirement ID	OBS-SRS-FR-01.00
Function / Entity	User Registration & Multi-Factor Authentication (MFA) Initialization
Description	Registers a new retail customer on the OBS platform and sets up their SMS-based or TOTP-based Multi-Factor Authentication.
Inputs	National ID number, primary mobile number, email address, password string, and OTP confirmation.
Source	Customer UI Registration Form and SMS/Authenticator Client.
Outputs	Newly created Customer Profile record, active database credential row, and screen validation banner.
Destination	Core Banking Database and User UI Screen.
Action to be Taken	1. Verify that the National ID is unique and not already registered. 2. Verify password meets strength criteria (minimum 8 characters, containing at least one digit, one special character, and one uppercase letter). 3. Dispatch a 6-digit verification code to the registered mobile number. 4. Validate user confirmation input; block process if incorrect code is entered thrice. 5. Hash the validated password securely prior to database storage. 6. Initialize account state as 'Pending Verification' and flag MFA as 'Active'.
Pre-conditions	User is not authenticated; registration page is open; system is online.
Post-conditions	Database contains a new, securely hashed, and pending-verification customer record.
Side Effects	Sends confirmation registration SMS to the user via SMS Gateway API.

4.2. Core Transaction 2: Secure Login & Session Initialization

Structured Form-Based Specification: OBS-SRS-FR-02.00	
Requirement ID	OBS-SRS-FR-02.00
Function / Entity	Authentication and Session Token Generation
Description	Authenticates users using passwords and dynamic MFA verification, and initializes a secure user session.
Inputs	User Identifier (National ID/Username), password string, and dynamic 6-digit MFA OTP code.
Source	Secure Web/Mobile Login Form and SMS/MFA app.
Outputs	Session token and customized dashboard display.
Destination	Client browser session storage and core database session logs.
Action to be Taken	1. For internal staff and corporate users, check if corporate Single Sign-On (SSO) is used; if so, delegate authentication to the company identity provider. Otherwise, retrieve stored credentials matching the user identity from the database. 2. Verify user password against database record (if local authentication is used). 3. If primary credentials match, trigger SMS/TOTP challenge. 4. Confirm the dynamic MFA input matches the computed server value. 5. Generate a session token containing roles, permissions, and an expiration timestamp. 6. Return authorization token and redirect the user to their designated dashboard.
Pre-conditions	User is unauthenticated; system has internet connectivity; user is registered.
Post-conditions	Client holds a valid session token; system records session details.
Side Effects	Logs authentication timestamp and client IP; invalidates any stale user session.

4.3. Core Transaction 3: Domestic Fund Transfer (Intra-Bank & ACH/Wire)

Structured Form-Based Specification: OBS-SRS-FR-03.00	
Requirement ID	OBS-SRS-FR-03.00
Function / Entity	Fund Transfer Core Transaction Handler
Description	Safely debits a customer's checking account and credits a destination bank account (internal or external clearing house) in an ACID-compliant transaction.
Inputs	Source Account Number, Destination IBAN, Transfer Amount, Transfer Type (Intra-bank, ACH, or RTGS), and Transaction PIN.
Source	Transfer Request UI Form and Secure Authentication Core.
Outputs	Updated balances in source/destination accounts, database ledger logs, and dynamic receipts.
Destination	Core Accounts Database, Shetab API Gateway, and User Receipts UI.
Action to be Taken	1. Retrieve source account status; confirm checking account is active and unrestricted. 2. Verify source balance is sufficient for amount + transfer fee. 3. Check destination IBAN format. If internal, verify account exists in active database. 4. Ensure the debit and credit actions are executed as an atomic database operation to prevent balance inconsistencies. 5. Debit source checking account balance and update transaction logs. 6. If internal, credit destination account. 7. If external, route the transfer request to the Shetab clearing network. 8. Generate transaction receipt and commit the ledger database modifications.
Pre-conditions	User is securely authenticated; session is active; daily limits are not exceeded.
Post-conditions	Source checking balance is debited; target balance is updated; database states are finalized.
Side Effects	Triggers transaction confirmation SMS alerts to both sending and receiving parties.

4.4. Core Transaction 4: Automatic Bill Payment & Utility Registration

Structured Form-Based Specification: OBS-SRS-FR-04.00	
Requirement ID	OBS-SRS-FR-04.00
Function / Entity	Bill Payment Engine
Description	Links utility billers to customer profiles and processes recurring or on-demand bill pay cycles.
Inputs	Customer Account Number, Biller ID, Bill Payment Token, and Scheduled Date.
Source	Customer Bill Pay Dashboard and External Utility APIs.
Outputs	Direct payments to utility provider registries and digital confirmation receipts.
Destination	Core Banking Database and External Utility Biller Gateways.
Action to be Taken	1. Connect to the designated utility biller database to fetch current outstanding amounts. 2. Validate checking account active state and verify sufficient funds exist. 3. Validate and secure the ledger state before initiating debit. 4. Debit account ledger by the specified bill amount. 5. Transmit the payment confirmation request to the external utility provider's billing gateway. 6. Store payment logs and render the digital payment confirmation details.
Pre-conditions	Customer session is validated; biller account details are matched.
Post-conditions	Customer balance is reduced by bill amount; utility bill status shows as 'Settled'.
Side Effects	Updates recurring calendar trackers; sends notification receipt via secure email.

4.5. Core Transaction 5: Statement Generation & PDF Export

Structured Form-Based Specification: OBS-SRS-FR-05.00	
Requirement ID	OBS-SRS-FR-05.00
Function / Entity	PDF Document Compilation Engine
Description	Queries transaction tables for specified date ranges, compiles chronological data, formats, and generates a downloadable PDF file.
Inputs	Account Number, Start Date, End Date, and Export Format (PDF/CSV).
Source	Customer Reports UI Page and Database Transaction History Tables.
Outputs	Securely structured, readable PDF report and download streams.
Destination	Client UI Interface and Web Download Pipeline.
Action to be Taken	1. Check user session to confirm ownership rights over the requested account number. 2. Apply user-selected query filters (e.g., date range, transaction type, amount range, or payee keyword). 3. Run query to fetch all transaction ledger records matching the filter criteria. 4. Parse raw filtered data to calculate starting balance, total deposits, and withdrawals. 5. Format and compile the retrieved transaction details into a structured PDF document. 6. Send the generated PDF file to the client UI to initiate download.
Pre-conditions	User is successfully logged in; date parameters are valid (Start Date $\leq$ End Date).
Post-conditions	Database states remain unchanged; client successfully downloads the PDF file.
Side Effects	Logs document creation metrics in the system logs for administrative security auditing.

5. Graphical UML Notations

This section contains the UML diagrams modeling the structural boundaries and behavioral workflows of the Online Banking System.

5.1. UML Use Case Diagram

The Use Case diagram below maps the relationships between the system boundary, the primary/secondary actors, and the core operational use cases.

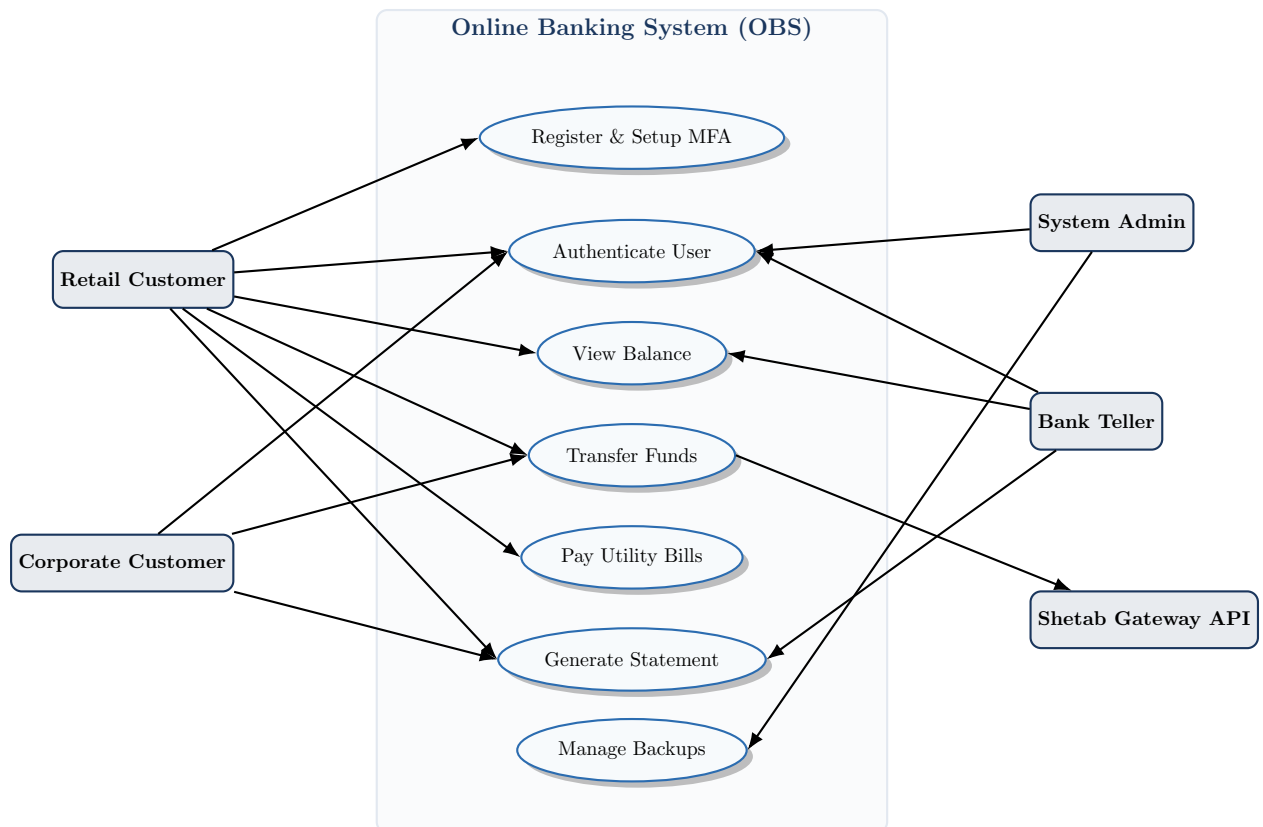


Figure 1: UML Use Case Diagram: User boundaries and actors mapping.

5.2. UML Sequence Diagram (Domestic Fund Transfer Workflow)

The sequence diagram below represents the step-by-step messaging workflow between system components during a domestic fund transfer transaction.

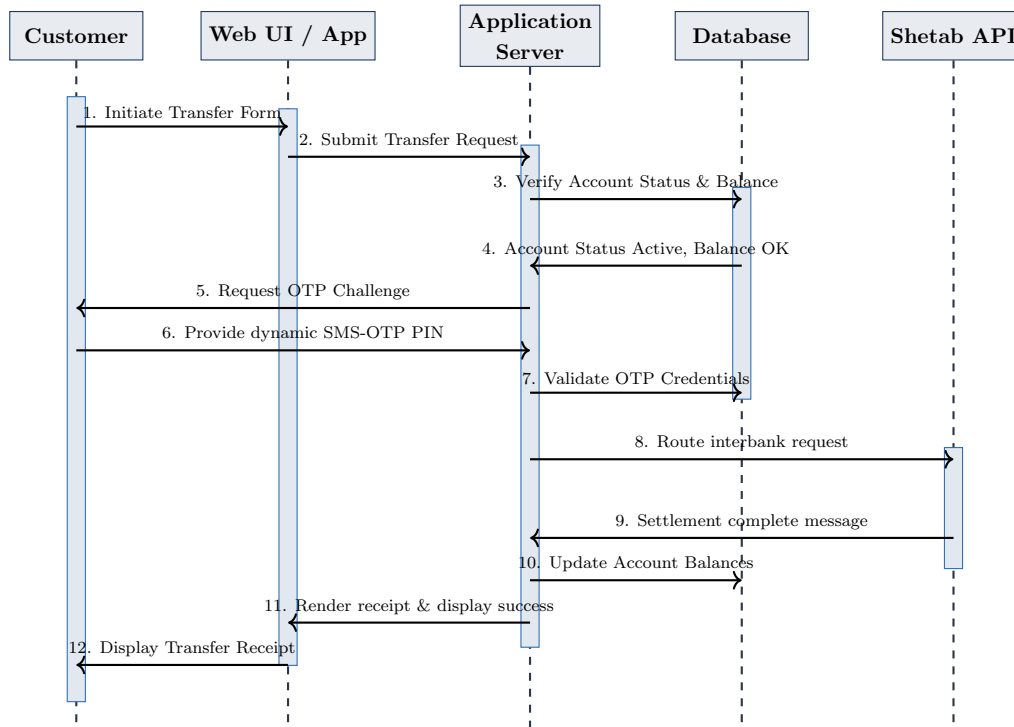


Figure 2: UML Sequence Diagram: Chronological flow of domestic fund transfer transaction.

6. Requirements Traceability & Verification Matrix

This section contains the Requirements Traceability Matrices (RTM) for the system. Each requirement is mapped to its priority category, the recommended verification method (Test, Demonstration, Inspection, or Analysis), and a specific testing scenario to verify compliance.

6.1. Functional Requirements Traceability Matrix

The matrix below maps the functional requirements to their respective verification plans.

Table 5: Online Banking System - Functional Traceability Matrix

Req. ID	Priority	Category	Verification Method	Verification / Testing Scenario
OBS-FR-01	Must	Authentication	Demonstration	Verify new account signup flows and database hash check.
OBS-FR-02	Must	Authentication	Test	Verify MFA TOTP/SMS challenge upon credential matching.
OBS-FR-03	Must	Authorization	Test	Verify RBAC menu rendering and endpoint access rules.
OBS-FR-04	Should	Authorization	Demonstration	Verify automatic token invalidation after 10 min idle time.
OBS-FR-05	Must	Data Processing	Test	Run concurrent transaction updates to verify ACID locks.
OBS-FR-06	Must	Data Processing	Inspection	Static analysis check of form parsing and SQLi/XSS filters.
OBS-FR-07	Should	UI/UX	Demonstration	Visual rendering checks across various browser viewport widths.
OBS-FR-08	Should	UI/UX	Inspection	Run screen-reader compliance check (WCAG 2.1 AA checklist).
OBS-FR-09	Must	Reporting	Test	Initiate statement generation and measure time-to-download.
OBS-FR-10	Could	Reporting	Demonstration	Check cron trigger at month-end and confirm PDF attachment delivery.
OBS-FR-11	Must	Third-Party	Test	Verify Shetab API response and cert handshake.
OBS-FR-12	Must	Third-Party	Demonstration	Confirm asynchronous SMS delivery upon transfers > \$10.00.
OBS-FR-13	Should	Error Handling	Demonstration	Trigger timeout exception and confirm modal text display.
OBS-FR-14	Must	Error Handling	Inspection	Inspect log output JSON format and error level fields.
OBS-FR-15	Must	Backup & Restore	Inspection	Verify backup snapshot cron job and encryption keys at rest.
OBS-FR-16	Must	Backup & Restore	Demonstration	Initiate failover and verify standby site active state transition.
OBS-FR-17	Could	Authentication	Test	Test SAML/OAuth redirect flows with external provider IDP.
OBS-FR-18	Could	Data Processing	Test	Query payee database and check return latency under load.
OBS-FR-19	Should	Third-Party	Test	Trigger balance threshold drop and confirm notification dispatch.
OBS-FR-20	Should	Error Handling	Demonstration	Submit a support ticket and check operator inbox queue.

6.2. Non-Functional Requirements Traceability Matrix

The matrix below maps the non-functional requirements to their respective verification scenarios and criteria.

Table 6: Online Banking System - Non-Functional Traceability Matrix

Req. ID	Priority	Category	Verification Method	Verification / Testing Scenario
OBS-NFR-01	Should	Usability	Test	Usability studies (measure signup setup duration/onboarding time).
OBS-NFR-02	Must	Security	Inspection	Audit system volumes and API ports to confirm AES-256/TLS 1.3.
OBS-NFR-03	Must	Security	Inspection	Verify database hash salt strength and Argon2id config parameters.
OBS-NFR-04	Must	Reliability	Test	Induce process kills mid-transfer and verify rollback completion.
OBS-NFR-05	Must	Performance	Test	Load test home page and measure response times under SLA limits.
OBS-NFR-06	Should	Scalability	Test	JMeter/Gatling simulation scaling up to 100,000 active sessions.
OBS-NFR-07	Must	Availability	Analysis	Review monthly SLA reports and check scheduled downtime logs.
OBS-NFR-08	Should	Compatibility	Demonstration	Run automated Selenium grid cross-browser compatibility tests.
OBS-NFR-09	Must	Reliability	Test	Run bi-weekly database backup restore automation verification checks.
OBS-NFR-10	Should	Usability	Test	Measure timestamp lag from ticket submission to operator routing.
OBS-NFR-11	Must	Security & Compliance	Inspection	Verify PCI-DSS audit parameters and 7-year storage key rotations.
OBS-NFR-12	Should	Maintainability	Analysis	Check SonarQube dashboards to confirm code test coverage $\geq 85\%$.